

Security+ 5.2 · Business Impact Analysis

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.2 — Business Impact Analysis (2:55)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: BIA: impacto de negócio se o processo crítico PARAR. MTR/MTTR (tempo de resposta); MTU (mean time to use); MTBF (mean time between failure). Alimenta RTO/RPO.

Highlights que a prova cobra

- BIA: quanto o negócio PERDE por hora/dia se processo crítico para
- MTTR: tempo de resposta/reparo; MTBF: confiabilidade

Dicas de prova & Cenários Típicos

- 'evaluates impact of losing critical process'=BIA

Cenário clássico de exame: 'empresa calcula quanto perderia na hora se o e-commerce caísse'=BIA.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.2 — Business Impact Analysis)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **BIA:** Business Impact Analysis: Análise de Impacto no Negócio que quantifica as consequências financeiras e operacionais da interrupção de processos críticos da empresa.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. RTO (Recovery Time Objective) mede:

- A)** Quanto DADO você aceita perder
- B)** Quanto TEMPO o serviço pode ficar fora
- C)** O custo do incidente
- D)** O número de usuários afetados

2. Se um servidor falha e precisa estar operacional em 4 horas conforme SLA, isso define:

- A)** RPO (Recovery Point Objective)
- B)** RTO (Recovery Time Objective)
- C)** MTTR (Mean Time To Repair)
- D)** MTBF (Mean Time Between Failures)

3. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'BIA: quanto o negócio PERDE por hora/dia se processo crítico para'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: BIA: quanto o negócio PERDE por hora/dia se processo crítico para...

4. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'MTTR: tempo de resposta/reparo; MTBF: confiabilidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: MTTR: tempo de resposta/reparo; MTBF: confiabilidade...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'evaluates impact of losing critical process'=BIA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'evaluates impact of losing critical process'=BIA...

6. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: "empresa calcula quanto perderia na hora se o e-commerce caísse"=BIA.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa calcula quanto perderia na hora se o e-commerce caísse'=BIA....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'BIA: quanto o negócio PERDE por hora/dia se processo crítico para'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: BIA: quanto o negócio PERDE por hora/dia se processo crítico para...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'MTTR: tempo de resposta/reparo; MTBF: confiabilidade'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: MTTR: tempo de resposta/reparo; MTBF: confiabilidade...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: "evaluates impact of losing critical process'=BIA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'evaluates impact of losing critical process'=BIA...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Business Impact Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: "empresa calcula quanto perderia na hora se o e-commerce caísse'=BIA.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'empresa calcula quanto perderia na hora se o e-commerce caísse'=BIA....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Quanto TEMPO o serviço pode ficar fora.

✓ **Por que está certa:** A alternativa correta é: quanto TEMPO o serviço pode ficar fora. O RTO (Recovery Time Objective) é uma métrica central no Plano de Continuidade de Negócios (BCP) e no Plano de Recuperação de Desastres (DRP), abordada no domínio de Continuidade de Negócios e Recuperação de Desastres da CompTIA Security+ SY0-701. Ele define o tempo máximo aceitável para restaurar um serviço ou processo após uma interrupção, antes que o impacto no negócio se torne inaceitável. Por exemplo, se um e-commerce define RTO de 2 horas, a equipe de recuperação deve restabelecer a operação em até 2 horas após o incidente. O RTO orienta a escolha de estratégias de recuperação (hot site, warm site, cold site), a frequência de backups e os investimentos em redundância. Ele é frequentemente confundido com RPO, mas enquanto o RTO mede tempo de inatividade, o RPO mede perda de dados.

✗ **Por que as outras estão erradas:**

- *Quanto DADO você aceita perder:* Essa é a definição de RPO (Recovery Point Objective), não de RTO. O RPO estabelece a quantidade máxima de dados que pode ser perdida, medida em tempo (ex.: 15 minutos de transações). Ele determina a frequência dos backups: se o RPO é de 1 hora, os backups devem ocorrer pelo menos a cada hora. O RTO, por sua vez, foca no tempo de restauração do serviço, não na perda de dados. Confundir os dois conceitos leva a estratégias de recuperação inadequadas, pois um RPO baixo não garante um RTO baixo, e vice-versa.
- *O custo do incidente:* O custo do incidente é uma métrica financeira que quantifica as perdas diretas e indiretas decorrentes de uma interrupção (receita perdida, multas, produtividade, danos à reputação). Embora seja um insumo para justificar investimentos em continuidade, não é a definição de RTO. O RTO é uma meta de tempo, não um valor monetário. Utilizar o custo como definição de RTO desviaria o foco do planejamento de recuperação, que precisa de parâmetros temporais claros para orientar ações técnicas.
- *O número de usuários afetados:* O número de usuários afetados é uma métrica de impacto, útil para priorização e comunicação, mas não define o RTO. O RTO é um objetivo de tempo de recuperação, independentemente da quantidade de usuários. Um serviço crítico para poucos usuários pode ter RTO curto, enquanto um serviço para muitos usuários pode ter RTO mais longo, dependendo da criticidade para o negócio. Portanto, essa alternativa não corresponde ao conceito formal de RTO.

2) B — RTO (Recovery Time Objective).

✓ **Por que está certa:** O RTO (Recovery Time Objective) é o tempo máximo aceitável para restaurar um serviço ou sistema após uma interrupção, conforme definido nos objetivos de continuidade de negócios. Se um SLA estabelece que o servidor deve estar operacional em até 4 horas, esse é exatamente o RTO: o prazo alvo para recuperação. A CompTIA Security+ distingue RTO de RPO e outras métricas, sendo o RTO focado no tempo de inatividade tolerável, não na perda de dados.

✗ **Por que as outras estão erradas:**

- *RPO (Recovery Point Objective):* O RPO (Recovery Point Objective) define a quantidade máxima de dados que a organização pode perder, medida em tempo (ex.: 1 hora de transações). Ele está relacionado à frequência de backups e à tolerância à perda de dados, não ao tempo de recuperação do serviço. Um SLA de 4 horas para restabelecer o servidor não descreve perda de dados, mas sim o tempo máximo de indisponibilidade, portanto não é RPO.
- *MTTR (Mean Time To Repair):* O MTTR (Mean Time To Repair) é uma métrica estatística que representa o tempo médio necessário para reparar um componente ou sistema após uma falha. É

uma medida histórica e operacional, não um objetivo contratual ou meta de recuperação. O SLA de 4 horas é uma meta prescritiva de recuperação, não uma média de reparos passados. Confundir MTTR com RTO é um erro conceitual comum, mas tecnicamente distinto.

• *MTBF (Mean Time Between Failures)*: O MTBF (Mean Time Between Failures) é a média de tempo entre falhas consecutivas de um sistema reparável, indicando sua confiabilidade. Ele não estabelece prazos de recuperação, mas sim a frequência esperada de falhas. Um SLA de 4 horas para restauração não tem relação com a frequência de falhas, mas com a rapidez da recuperação. Portanto, MTBF não responde à definição apresentada.

3) D — Implementar a solução correspondente: BIA: quanto o negócio PERDE por hora/dia se processo crítico para....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): BIA: quanto o negócio PERDE por hora/dia se processo crítico para.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: MTTR: tempo de resposta/reparo; MTBF: confiabilidade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): MTTR: tempo de resposta/reparo; MTBF: confiabilidade.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'evaluate impact of losing critical process'=BIA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): 'evaluate impact of losing critical process'=BIA.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'empresa calcula quanto perderia na hora se o e-commerce caísse' = BIA.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): 'empresa calcula quanto perderia na hora se o e-commerce caísse' = BIA..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: BIA: quanto o negócio PERDE por hora/dia se processo critico para....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): BIA: quanto o negócio PERDE por hora/dia se processo critico para.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: MTTR: tempo de resposta/reparo; MTBF: confiabilidade....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): MTTR: tempo de resposta/reparo; MTBF: confiabilidade.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'evaluates impact of losing critical process'=BIA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): 'evaluates impact of losing critical process'=BIA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'empresa calcula quanto perderia na hora se o e-commerce caísse'=BIA.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Business Impact Analysis): 'empresa calcula quanto perderia na hora se o e-commerce caísse'=BIA..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.